Studio Nx

Backend(FastAPI/Python) 31 — set_refresh_cookie() · clear_refresh_cookie()

2026-10-12

Backend(FastAPI/Python) 31 — `set_refresh_cookie()` · `clear_refresh_cookie()`

항목	내용
파일	`studionx/backend/app/api/v1/auth.py`
작업	P1-05 로그인: 리프레시 쿠키 (PRD 01 FR-105, FR-109)
작성	Claude (AI), 2026-10-07, 사용자 검토
이전 · 다음	30 `get_active_user()` · 32 `POST /auth/login`

1. 하는 일

리프레시 토큰(27)을 브라우저 **쿠키**에 심고(`set`), 로그아웃할 때 지웁니다(`clear`). 두 함수 모두 응답 헤더 `Set-Cookie` 한 줄을 만듭니다.

호출	응답 헤더 `Set-Cookie`
`set_refresh_cookie(res, token, remember=True)`	`snx_refresh=eyJ…; HttpOnly; Max-Age=259200; Path=/api/v1/auth; SameSite=lax`
`set_refresh_cookie(res, token, remember=False)`	`snx_refresh=eyJ…; HttpOnly; Path=/api/v1/auth; SameSite=lax`
`clear_refresh_cookie(res)`	`snx_refresh=""; expires=(지금); HttpOnly; Max-Age=0; Path=/api/v1/auth; SameSite=lax`

쿠키 속성	값	뜻
`HttpOnly`	켬	**JS가 읽을 수 없습니다** (`document.cookie`에 보이지 않습니다). 그래서 스크립트 공격(XSS)이 훔쳐 가지 못합니다
`Path=/api/v1/auth`		`/api/v1/auth/…` 요청에만 실립니다. 다른 API나 페이지 요청에는 실리지 않습니다
`SameSite=lax`		다른 사이트가 몰래 보낸 `POST` 요청에는 실리지 않습니다 (CSRF 대비)
`Max-Age`	259200초(3일) 또는 없음	없으면 **세션 쿠키**가 되어 브라우저를 닫을 때 사라집니다
`Secure`	배포 환경(`APP_ENV=prod`)에서만 켬	HTTPS로만 보냅니다. 개발 환경(`http://localhost`)에서 켜면 쿠키가 아예 실리지 않아서 꺼 둡니다

2. 언제 쓰나

쓰는 곳	함수	화면
32 `POST /auth/login`	`set_refresh_cookie(…, remember=data.remember)`	로그인 모달의 **Keep me signed in** 체크 여부
34 `POST /auth/logout`	`clear_refresh_cookie()`	헤더의 **Sign Out** (JS 08)

Keep me signed in	브라우저를 닫았다가 다시 열면
체크함	3일 동안 쿠키가 남아 있어서 `api.js`가 재발급을 받고, 로그인된 상태가 유지됩니다

Keep me signed in	브라우저를 닫았다가 다시 열면
체크하지 않음	쿠키가 사라져서 재발급에 실패하고, 로그인 화면으로 갑니다

3. 코드

import (파일 맨 위)

```
from typing import Annotated

from fastapi import APIRouter, Cookie, Query, Response, status
from pydantic import EmailStr

from app.api.deps import Db
from app.core.config import get_settings
from app.schemas.auth import (
    AvailabilityResponse,
    LoginRequest,
    Nickname,
    SignupRequest,
    SignupResponse,
    TokenResponse,
)
from app.schemas.common import ErrorResponse
from app.services import auth_service
```

`auth.py` 맨 위의 import입니다. **`from app.core.config import get_settings`를 이번에 추가했습니다.** 이 함수들은 `Response`와 `get_settings`를 사용합니다.

함수

```
REFRESH_COOKIE = "snx_refresh"
REFRESH_COOKIE_PATH = "/api/v1/auth"


def set_refresh_cookie(response: Response, token: str, remember: bool) -> None:
    settings = get_settings()
    if remember:
        max_age = settings.jwt_refresh_days * 24 * 60 * 60
    else:
        max_age = None
    response.set_cookie(
        key=REFRESH_COOKIE,
        value=token,
        path=REFRESH_COOKIE_PATH,
        httponly=True,
        samesite="lax",
        secure=settings.app_env == "prod",
        max_age=max_age,
    )


def clear_refresh_cookie(response: Response) -> None:
    response.delete_cookie(
        REFRESH_COOKIE,
```

```
        path=REFRESH_COOKIE_PATH,
        httponly=True,
        samesite="lax",
        secure=get_settings().app_env == "prod",
    )
```

문법 풀이

import 문법	뜻
`from app.core.config import get_settings`	`.env`를 읽어 만든 설정입니다 (05번과 같음)

식	뜻
`response: Response`	라우터가 받은 응답 객체입니다. 여기에 쿠키를 붙이면 응답 헤더로 나갑니다
`response.set_cookie(key=…, value=…, …)`	`Set-Cookie` 헤더 한 줄을 만듭니다
`max_age=None`	`Max-Age`를 아예 쓰지 않습니다. 그러면 세션 쿠키가 됩니다
`settings.app_env == "prod"`	배포 환경이면 `True`입니다
`response.delete_cookie(…)`	값이 비어 있고 `Max-Age=0`인 같은 이름의 쿠키를 보내서, 브라우저가 쿠키를 지우게 합니다
`-> None`	돌려주는 값이 없습니다. `response`를 바꾸는 것이 이 함수의 일입니다

4. 흐름

심기: 수명을 정하고(체크했으면 3일, 아니면 없음), 속성을 붙여 `Set-Cookie`를 만듭니다.

지우기: 같은 이름과 같은 경로로 "지금 만료되는" 쿠키를 보냅니다.

5. 왜 이렇게

선택	이유
응답 본문이 아니라 쿠키에 담음	본문으로 주면 JS가 어딘가에 저장해야 합니다. `HttpOnly` 쿠키는 JS가 손댈 수 없고, 브라우저가 알아서 보냅니다
경로를 `/api/v1/auth`로 좁힘	3일짜리 토큰이 모든 요청에 실려 다니지 않습니다. 재발급과 로그아웃할 때만 서버로 갑니다
체크하지 않으면 세션 쿠키	공용 컴퓨터에서 브라우저를 닫으면 로그인이 풀립니다 (FR-109)
`Secure`는 배포 환경에서만 켬	개발 서버는 `http://`라서 `Secure` 쿠키가 실리지 않습니다. 배포 환경(HTTPS)에서는 반드시 켭니다
지울 때도 같은 속성을 씀	브라우저는 이름과 경로가 같아야 같은 쿠키로 보고 지웁니다. 템플릿은 경로만 맞췄지만, 속성까지 같게 해 두면 브라우저마다 다르게 처리할 걱정이 없습니다

6. 시험 (`tests/test_auth_cookies.py` 새 파일, 5개)

시험	확인한 것
체크함	`snx_refresh=TOKEN`, `Max-Age=259200`, `Path=/api/v1/auth`, `HttpOnly`, `SameSite=lax`
체크하지 않음	`Max-Age`와 `expires`가 없고(세션 쿠키), `HttpOnly`가 있습니다
`Secure` (2개)	설정을 `dev`로 바꾸면 없고, `prod`로 바꾸면 있습니다
지우기	값이 비어 있고, `Max-Age=0`이며, 경로가 같습니다

전체 시험 218개가 통과했고, `ruff` 검사도 통과했습니다.